Lecture 2.1: IAM

Maharishi International University

Department of Computer Science

M.S. Thao Huy Vu

Maharishi International University - Fairfield, Iowa

All rights reserved. No part of this slide presentation may be reproduced or utilized in any form or by any means, electronic or mechanical, including photocopying or recording, or by any information storage and retrieval system, without permission in writing from Maharishi International University (MIU).

Agenda

- IAM
- Group
- User
- Policy
- Best practices for IAM security

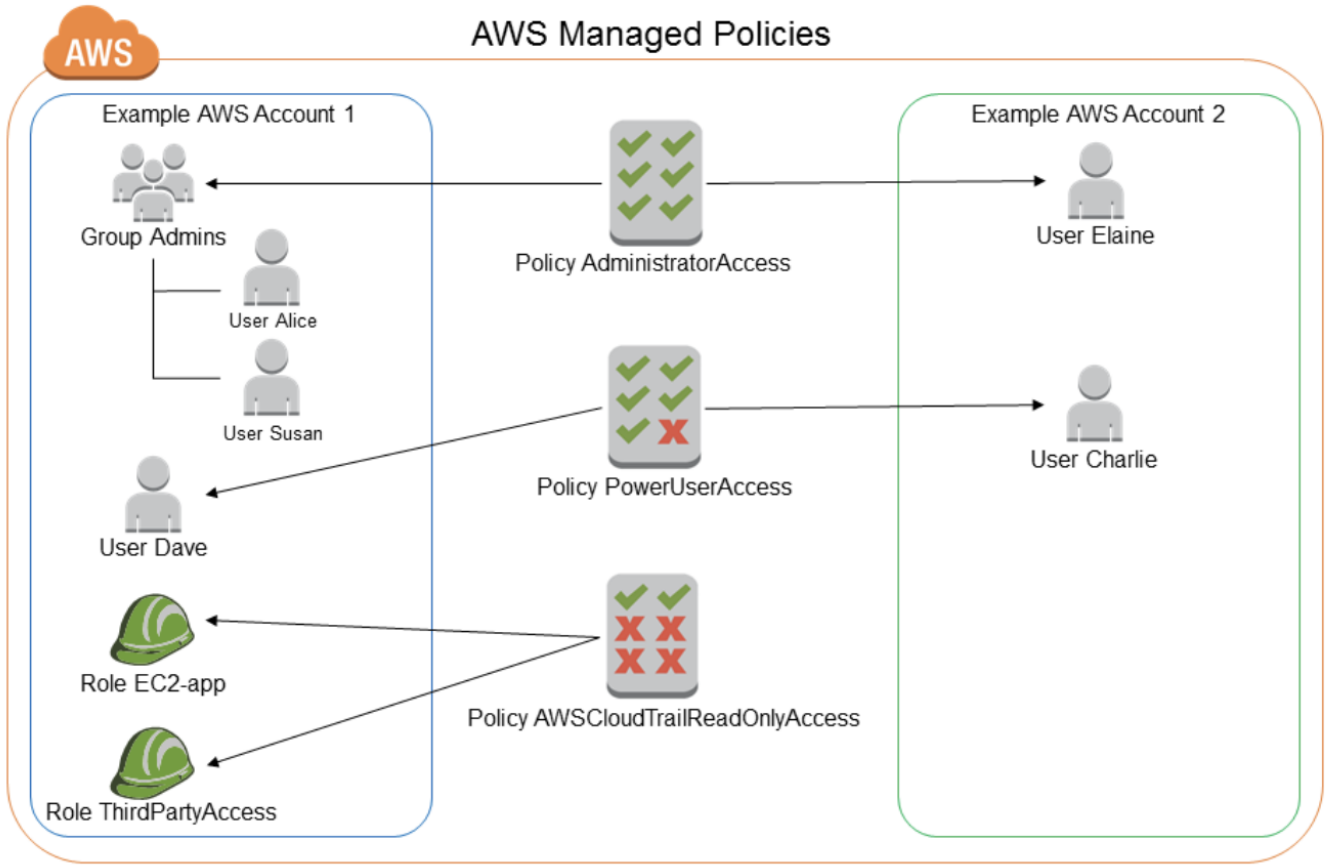
IAM - Introduction

- AWS Identity and Access Management (IAM)
- Manage access to AWS services and resources **securely**
- Create and manage AWS users
- Allow/deny access to AWS resources
- Ensure only **authenticated** and **authorized** users can access resources

IAM – Core components

- Users
- Group
- Role
- Policy

IAM - Examples



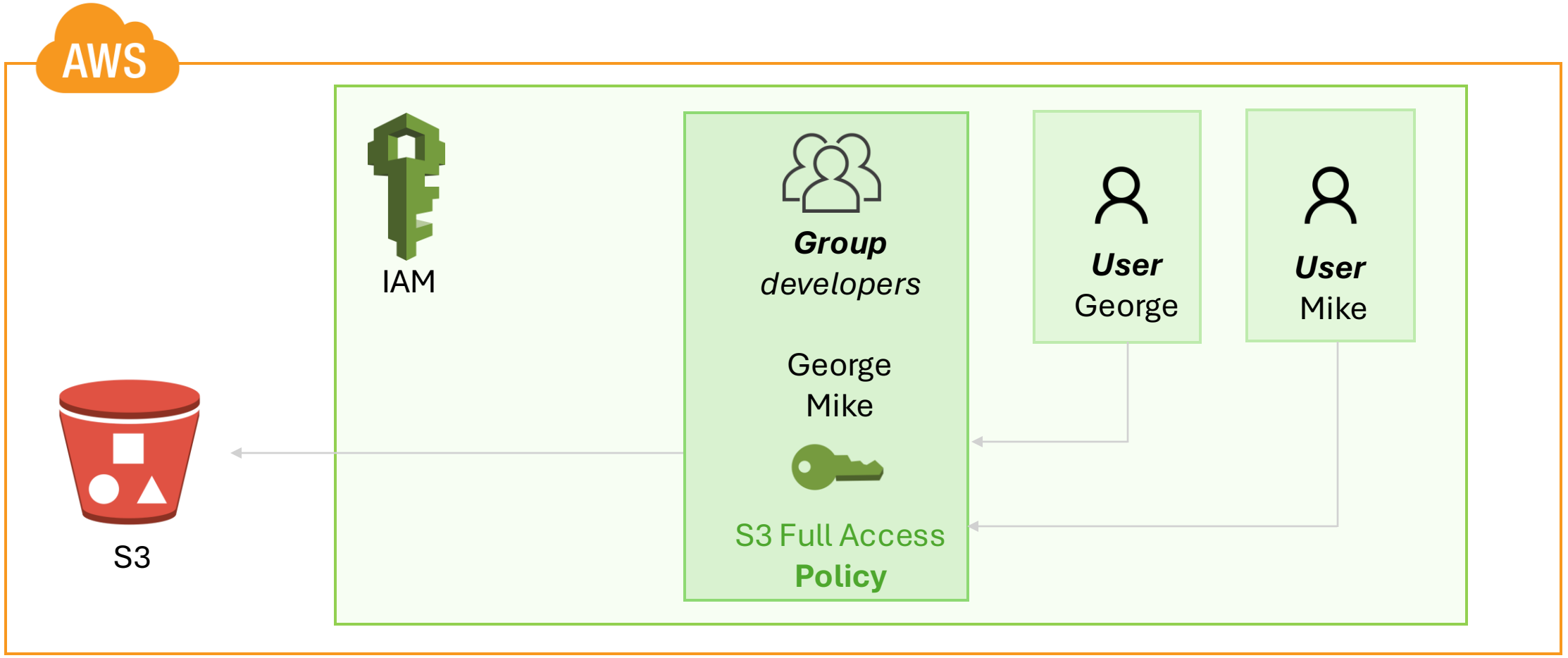
IAM – Key Features

- Centralized Control of AWS Account: Given a central area to manage users and security credentials
- Shared Access to your AWS account: Grant other people permission to use resources
- Granular Permissions: Grant different permissions to different people for different resources
- Identity Federation: Support for identity federation like Active Directory, Facebook, LinkedIn, etc. That means allowing users to log in to AWS using their existing credentials
- Multifactor Authentication (MFA): Add two-factor authentication
- Temporary Access for Users: Provide users with temporary access to AWS resources

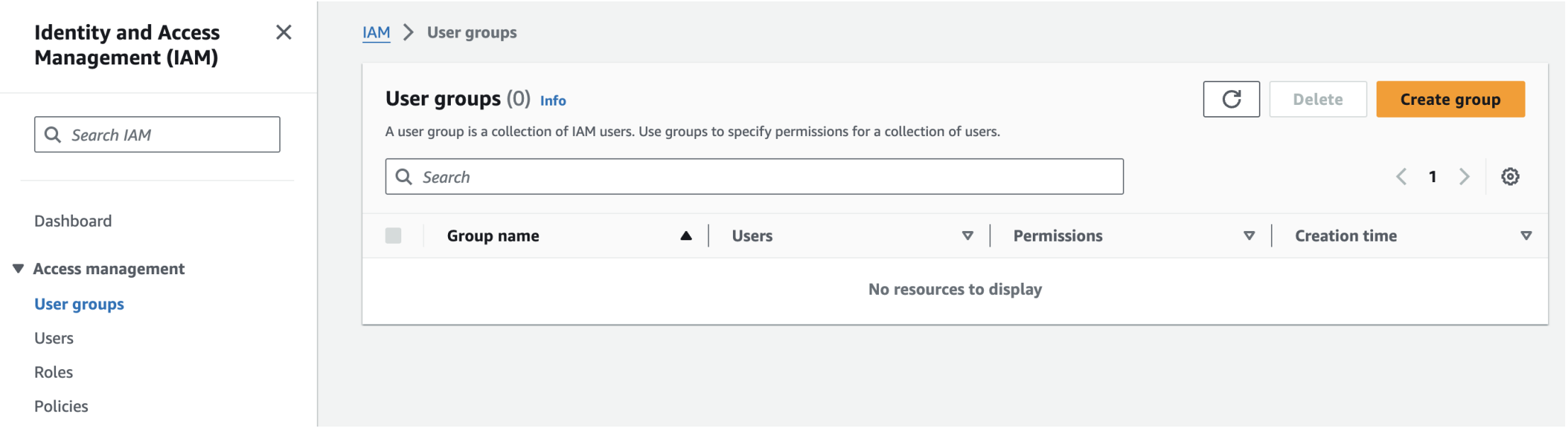
Users and Groups

- Users
  - An entity represents a **person** or **service** that interacts with AWS resources
  - Provide individual **credentials** for accessing AWS services, ensuring accountability and traceability
  - Each has a name, credentials (passwords, access keys), and permissions assigned through policies
- Groups
  - A **collection** of users with specific permissions
  - Manage permissions at a group level rather than at the individual user level
  - Groups have policies attached to them which apply to all users in the group

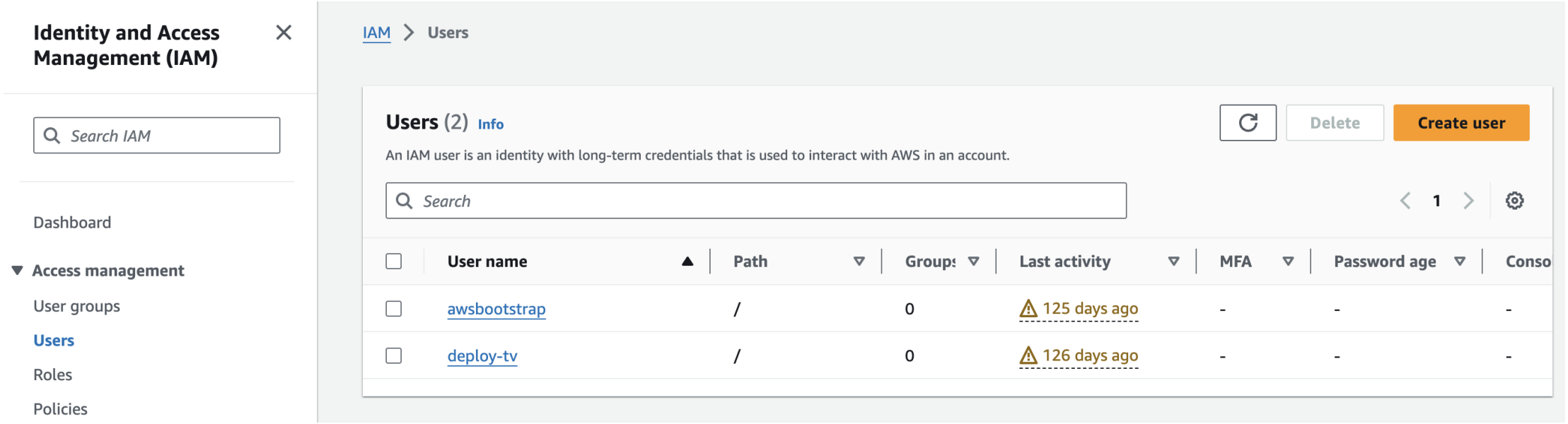
AWS IAM Group



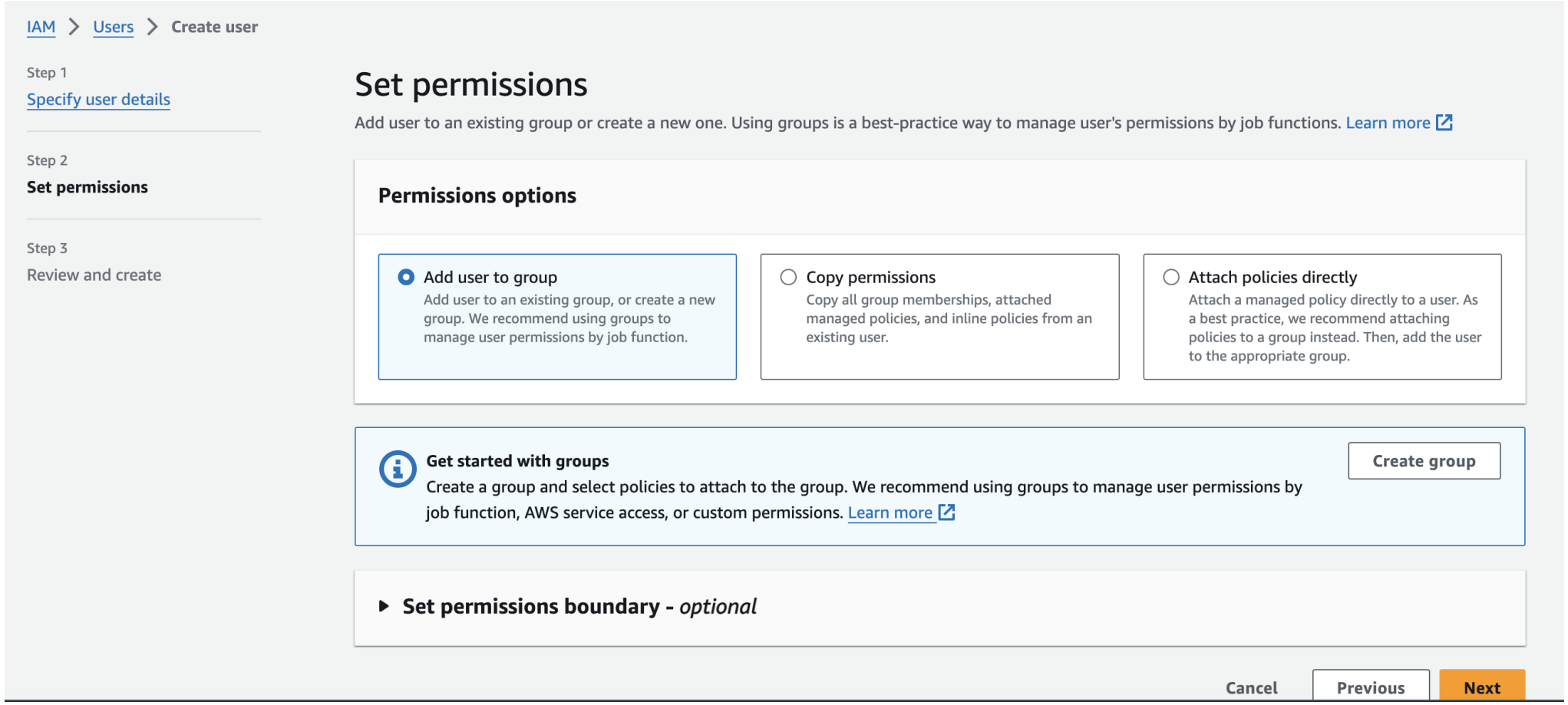
Users & Groups – Create IAM User Groups



Users & Groups – Create IAM users



Users & Groups – Create IAM users



Policy

- A policy is a JSON document that defines permissions to allow or deny actions on AWS resources
- Control Access: Ensure users and roles have the appropriate access to AWS resources
- Granular Control: Specify exactly what actions are allowed or denied

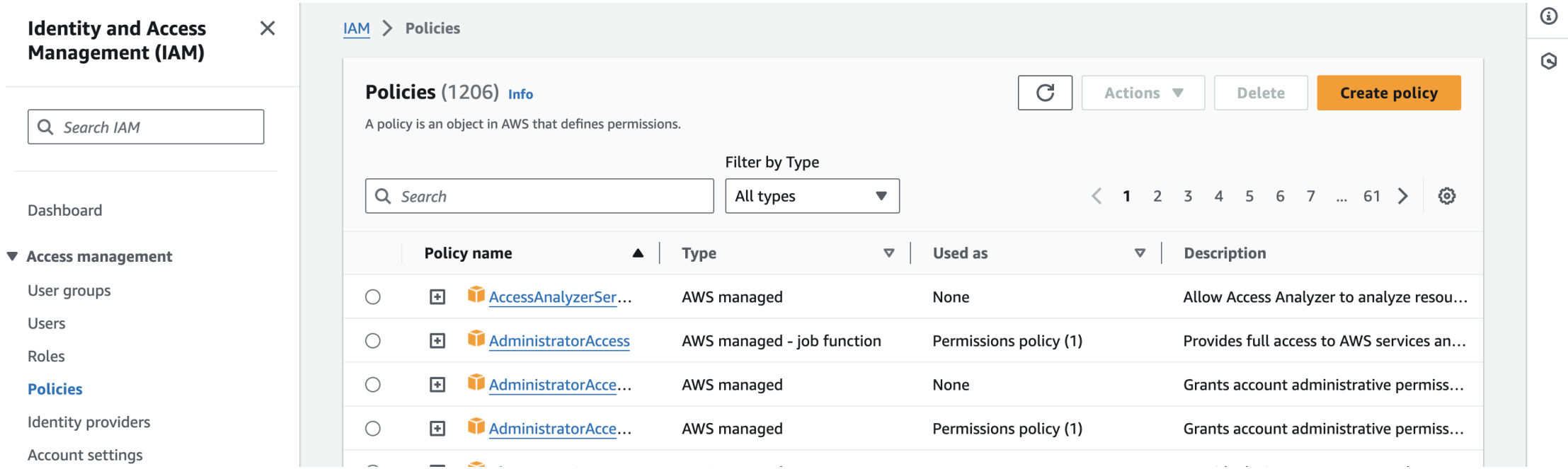
Policy

- **Identity-based** policies – Attach policies to IAM identities (users, groups, or roles) as we talked about in the previous slides.
  - Managed Policies:
    - AWS Managed Policies: Predefined policies created and managed by AWS, which are designed to provide permissions for common use case
    - Customer Managed Policies: Policies created and managed by User, allowing for custom permission sets.
  - Inline policies: Policies that are directly attached to a single user, group, or role. They are not shared.
- **Resource-based** policies – Attach inline policies to resources (such as S3, SQS, SNS) directly. Resource-based policies have a **principal** tag that defines who can the actions defined.

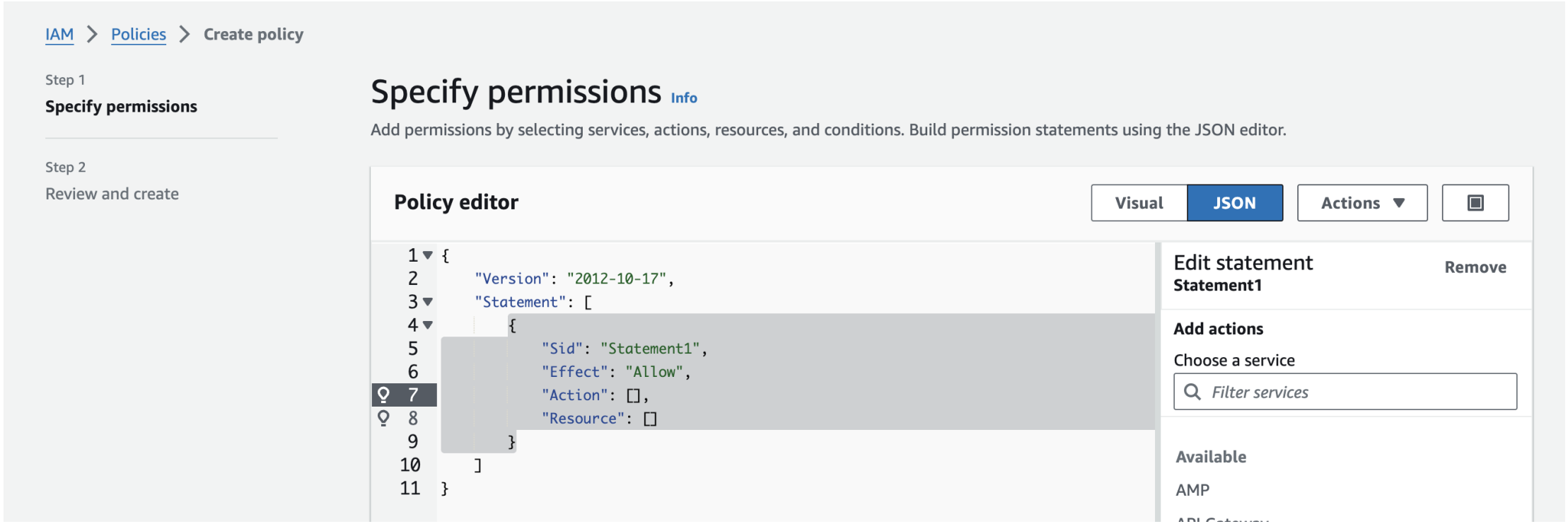
Policy - Example

- For example, if you want to connect EC2 with S3, you can do it in 2 ways.
  - Identity-based authorization: Add a role to EC2.
  - Resource-based authorization: Write a resource-based policy on the S3.

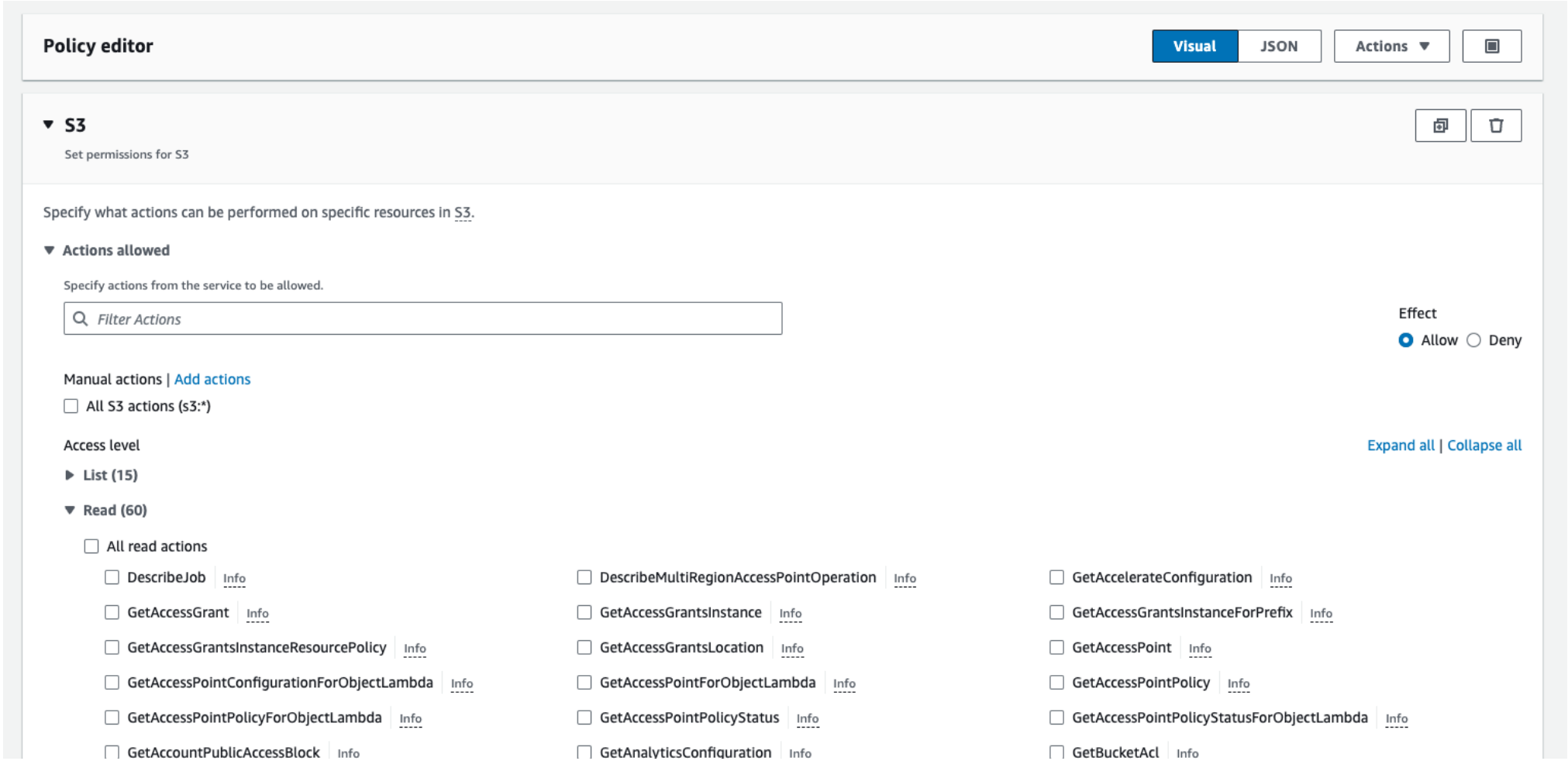
Policy


Identity and Access Management (IAM)
Search IAM
Dashboard
Access management
User groups
Users
Roles
Policies
Identity providers
Account settings
IAM > Policies
Policies (1206) Info
A policy is an object in AWS that defines permissions.
Actions
Delete
Create policy
Filter by Type
Search
All types
1 2 3 4 5 6 7 ... 61
Policy name
Type
Used as
Description
AccessAnalyzerSer...
AWS managed
None
Allow Access Analyzer to analyze resou...
AdministratorAccess
AWS managed - job function
Permissions policy (1)
Provides full access to AWS services an...
AdministratorAcce...
AWS managed
None
Grants account administrative permiss...
AdministratorAcce...
AWS managed
Permissions policy (1)
Grants account administrative permiss...

Policy


IAM > Policies > Create policy
Step 1
Specify permissions
Step 2
Review and create
Specify permissions Info
Add permissions by selecting services, actions, resources, and conditions. Build permission statements using the JSON editor.
Policy editor
Visual
JSON
Actions
{
"Version": "2012-10-17",
"Statement": [
{
"Sid": "Statement1",
"Effect": "Allow",
"Action": [],
"Resource": []
}
]
}
Edit statement
Statement1
Remove
Add actions
Choose a service
Filter services
Available
AMP

Policy


Policy editor
Visual
JSON
Actions
S3
Set permissions for S3
Specify what actions can be performed on specific resources in S3.
Actions allowed
Specify actions from the service to be allowed.
Filter Actions
Effect
Allow
Deny
Manual actions | Add actions
All S3 actions (s3:*)
Access level
Expand all | Collapse all
List (15)
Read (60)
All read actions
DescribeJob Info
DescribeMultiRegionAccessPointOperation Info
GetAccelerateConfiguration Info
GetAccessGrant Info
GetAccessGrantsInstance Info
GetAccessGrantsInstanceForPrefix Info
GetAccessGrantsInstanceResourcePolicy Info
GetAccessGrantsLocation Info
GetAccessPoint Info
GetAccessPointConfigurationForObjectLambda Info
GetAccessPointForObjectLambda Info
GetAccessPointPolicy Info
GetAccessPointPolicyForObjectLambda Info
GetAccessPointPolicyStatus Info
GetAccessPointPolicyStatusForObjectLambda Info
GetAccountPublicAccessBlock Info
GetAnalyticsConfiguration Info
GetBucketAcl Info

Best practices for IAM Security

- Least Privilege Principle
- Use Groups to Assign Permissions
- Enable Multi-Factor Authentication (MFA)
- Use IAM Roles for Applications
- Regularly Rotate Credentials
- Implement Strong Password Policies
- Monitor and Audit IAM Activity

Least Privilege Principle

- Least Privilege Principle: Grant only the permissions necessary for users to perform their job functions.
- Actions:
  - Regularly review and audit permissions.
  - Use IAM policies to grant specific permissions rather than broad ones
  - Create Roles with limited permissions for specific tasks

Least Privilege Principle

- S3ReadOnlyAccess

```
{
 "Version": "2012-10-17",
 "Statement": [
  {
   "Effect": "Allow",
   "Action": [
    "s3:GetObject",
    "s3:ListBucket"
   ],
   "Resource": [
    "arn:aws:s3:::example-bucket",
    "arn:aws:s3:::example-bucket/*"
   ]
  }
 ]
}
```

Use Groups to Assign Permissions

- Simplifies permissions management by grouping users with similar job functions
- Actions:
  - Create IAM groups for different roles (e.g, Developers, Admins).
  - Assign policies to groups rather than individual users

Enable Multi-factor Authentication (MFA)

- Adds an extra layer of security by requiring a second from of authentication
- Actions:
  - Enable MFA for all IAM users, especially those with privileged access
  - Use Virtual MFA devices for easy setup

Use IAM Roles for Applications

- Provides temporary credentials for applications running on AWS services without embedding long-term credentials in code.
- Create IAM roles with specific permissions for your applications
- Assign roles to AWS services that need to access resources

Regularly Rotate Credentials

- Regularly update and replace access keys and passwords to reduce the risk of compromised credentials
- Actions:
  - Rotate access keys for IAM users periodically
  - Implement policies requiring regular password changes

Implement Strong Password Policies

- Enforce password complexity and change requirements to enhance security
- Actions:
  - Set up a password policy in IAM to enforce strong passwords
  - Require password expiration and prevent reuse of old passwords

Monitor and Audit IAM Activity

- Use AWS CloudTrail, AWS Config, and IAM Access Analyzer to monitor and audit IAM activities
- Actions:
  - Enable CloudTrail to log all IAM API calls
  - Use AWS Config to track changes to IAM resources
  - Regularly review IAM Access Analyzer findings for potential security issues

IAM Identity Center

- AWS started recommending to use the IAM Identity Center for giving AWS access to developers. IAM Identity Center benefits:
  - Multi-account management. Multi accounts benefits are:
    - Better cost management
    - Better access management (read-only to production)
    - Remediate service quote per account
  - Single Sign On (SSO) – Not only AWS, you can also access popular apps such as Slack, Asana, GitHub through IAM Identity Center.

References

- https://docs.aws.amazon.com/
- ChatGPT: https://chatgpt.com/
- Google AI: https://gemini.google.com/app